

5 Laboratorinis darbas. Daugiafaktorinis autentifikavimas

Daugiafaktorinis autentifikavimas

Daugiafaktorinis autentifikavimas (angl. *multi-factor authentication*) (MFA) arba dviejų faktorių autentifikavimas (angl. *two-factor authentication*) (2FA) yra toks autentifikavimo metodas, kai vartotojas turi pateikti daugiau nei vieno tipo įrodymus, kad galėtų patvirtinti autentifikavimą sistemoje. Autentifikavimo tipai:

- 1 Tai, ką vartotojas žino
- 2 Tai, ką vartotojas turi
- 3 Tai, kas vartotojas yra
- 4 Tai, kur vartotojas yra
- 5 Tai, ką vartotojas daro

Privalumai

- Dažniausias būdas, kaip neteisėtai gaunama prieiga prie vartotojų paskyrų - silpni slaptažodžiai. MFA apsaugo tokias paskyras
- Leidžia padengti vieno autentifikavimo metodo trūkumus, kito privalumais

Trūkumai

- Mažiau technologiškai raštingiems vartotojams gali kilti problemų naudojant MFA
- Speciali aparatinė įranga, reikalinga kai kuriems MFA tipams, gali būti brangi
- Jei vartotojai praras prieigą prie savo MFA, gali prarasti prieigą prie savo paskyrų
- Įveda papildomo sudėtingumo į sistemą
- Daugeliui MFA sprendimų reikia išorinių išteklių, jie gali turėti saugumo spragų
- Užpuolikai gali pasinaudoti procesais skirtais vartotojams apeiti arba atstatyti MFA
- MFA reikalavimas gali neleisti kai kuriems vartotojams prisijungti prie sistemos

Tai, ką vartotojas žino

Žiniomis pagrįstas, autentifikavimo tipas; dažniausiai slaptažodis. Didžiausias šio faktoriaus privalumas - nei vartotojui, nei programuotojui, nereikia jokios specialios techninės įrangos ar integracijos su kitomis paslaugomis.

Dažniausias autentifikavimo būdas. Dauguma MFA sistemų naudoja slaptažodžius kaip vieną iš autentifikavimo faktorių.

Privalumai

- 1 Paprasta ir gerai suprantama
- 2 Lengva implementuoti

Trūkumai

- 1 Vartotojai yra linkę rinktis per lengvus slaptažodžius
- 2 Vartotojai tuos pačius slaptažodžius naudoja keliose sistemose
- 3 Jautrūs *phishing* atakoms

Saugumo klausimai (angl. *security questions* arba *recovery questions*), dažniausiai būna naudojami paskyros atgavimui pamiršus slaptažodį. **Nebepripažįstama priimtinu autentifikacijos faktoriumi**

Privalumai

- 1 Paprasta ir gerai suprantama
- 2 Lengva implementuoti

Trūkumai

- 1 Klausimai dažnai turi lengvai nuspėjamus atsakymus
- 2 Atsakymus į klausimus dažnai galima rasti vartotojų socialiniuose tinkluose
- 3 Klausimai turi būti parinkti tokie, kad vartotojai nepamirštų atsakymų
- 4 Jautrūs *phishing* atakoms

Tai, ką vartotojas turi

Turėjimu pagrįstas, autentifikavimo tipas. Pagrįstas fiziniu arba skaitmeniniu daiktu padedančiu autentifikuotis. Antras dažniausiai naudojamas MFA tipas.

Dažniausiai naudoja laiku paremtus (angl. *time-based*, TOTP) arba maišos funkcijomis paremtus (angl. *HMAC-based*, HOTP) vienkartinius slaptažodžius. Šiuos slaptažodžius generuoja fizinis įrenginys – kodų generatorius.

Privalumai

- 1 Generatoriai būna atskiri įrenginiai, todėl užpuolikams neįmanoma jų pažeisti nuotoliniu būdu

Trūkumai

- 1 Kodų generatoriai gali būti brangūs
- 2 Jei vartotojas pames generatorių, naujo gavimas gali užtrukti
- 3 Pavogti generatoriai gali būti naudojami be PIN kodo
- 4 Jautrūs *phishing* atakoms (bet trumpam)

TOTP generuoja programinė įranga. Dažnai implementuojama nuskaičius QR kodą autentifikatoriaus aplikacija.

Privalumai

- 1 Nereikalauja išduoti fizinių generatorių
- 2 Plačiai naudojama, todėl vartotojai dažnai jau turi autentifikatoriaus aplikaciją
- 3 Telefono ekrano užrakavimo funkcija, neleidžia pasiekti vienkartinio slaptažodžio užpuolikams

Trūkumai

- 1 TOTP programėlės dažniausiai būna sudiegtos telefonuose, o telefonai gali būti pažeidžiami
- 2 Aplikacija gali būti sudiegta tame pačiame įrenginyje, iš kurio bandoma autentifikuotis
- 3 Ne visi vartotojai turi telefonus su TOTP
- 4 Jei vartotojas praras telefoną, negalės autentifikuotis
- 5 Jautrūs *phishing* atakoms (bet trumpam)

Skaitmeniniai sertifikatai saugomi vartotojo įrenginyje. Dažniausiai būna implementuoti kaip skaitmeniniai parašai

Privalumai

- 1 Paprasta naudoti
- 2 Atsparūs *phishing* atakoms

Trūkumai

- 1 Gali būti sudėtinga įdiegti
- 2 Saugomi vartotojo įrenginyje, todėl gali būti pavogti, jei užpuolikas gaus fizinę prieigą prie įrenginio

Panašios į banko korteles. Saugoja skaitmeninį sertifikatą, kuris atrakinamas PIN kodu.

Privalumai

- 1 Pavogtos išmaniosios kortelės negali būti naudojamos be PIN kodo
- 2 Gali būti naudojamos keliose sistemose
- 3 Atsparios *phishing* atakoms

Trūkumai

- 1 Brangiai kainuoja
- 2 Autentifikavimui naršyklėje, reikalinga speciali aparatinė įranga

SMS žinutės arba telefono skambučiai gali būti naudojami suteikti vienkartinį kodą. Šie metodai turi daug rizikų, todėl neturėtų būti naudojami autentifikavimui aplikacijose, kuriose saugoma asmenį identifikuojanti informacija.

Privalumai

- 1 Lengva implementuoti

Trūkumai

- 1 Reikalauja vartotojui turėti telefoną
- 2 Reikalauja vartotojui turėti prieigą prie ryšio arba interneto
- 3 Gali kainuoti. Užpuolikai gali tyčia eikvoti lėšas
- 4 Dažnai SMS gauna tas pats įrenginys, kaip ir iš kurio jungiasi vartotojas
- 5 Jautrus *phishing* atakoms
- 6 SMS galima peržiūrėti ir kai įrenginys užrakintas
- 7 SMS gali perskaityti nesaugios aplikacijos

El. pašto autentifikacija reikalauja, kad vartotojas paspaustų nuorodą arba įvestų kodą gautą el. paštu.

Privalumai

- 1 Lengva implementuoti
- 2 Nereikalauja papildomos aparatinės įrangos

Trūkumai

- 1 Paremtas el. pašto saugumu. El. paštai dažnai patys neturi MFA
- 2 El. pašto slaptažodžiai dažnai sutampa su aplikacijos slaptažodžiais
- 3 Nesuteikia apsaugos, jei vartotojo el. paštas buvo nulaulytas
- 4 Dažnai laišką gauna tas pats įrenginys, kaip ir iš kurio jungiasi vartotojas
- 5 Jautrus *phishing* atakoms

Tai, kas vartotojas yra

Ilgimiau pagrįstas autentifikavimas yra pagrįstas fizinėmis vartotojo savybėmis. Dažnai naudojamas autentifikavimui fizinėse vietose, operacinėse sistemose, telefonuose, rečiau - *web* aplikacijose. Labiausiai pažeidžia privatumą.

Dažni biometrinės autentifikacijos būdai:

- Pirštų antspaudų skanavimas
- Veido atpažinimas
- Akies rainelės skanavimas
- Balso atpažinimas

Privalumai

- 1 Gerai implementuotą biometrinę autentifikaciją sunku suklastoti
- 2 Lengva ir patogiu naudoti vartotojams

Trūkumai

- 1 Vartotojui reikia pačiam nuskaityti savo duomenis
- 2 Reikalinga specifinė (kartais brangi) įranga
- 3 Reikia saugoti jautrius fizinius duomenis apie vartotojus

Tai, kur vartotojas yra

Vieta pagrįstas autentifikavimas yra pagrįstas vartotojo fizine vieta.

IP adresas, iš kurio vartotojas jungiasi, gali būti naudojamas kaip autentifikavimo faktorius, paprastai taikant *whitelist*.

Privalumai

- 1 Labai paprasta vartotojams
- 2 Reikalauja nedaug konfigūracijos administratoriams

Trūkumai

- 1 Nesuteikia apsaugos jei vartotojas praranda prieigą prie įrenginio
- 2 Patikimi IP adresai turi būti atidžiai atrenkami

Vietoj IP adreso naudojama IP adreso registruota geografinė vieta. Labai netikslus autentifikavimo būdas.

Privalumai

- 1 Labai paprasta vartotojams

Trūkumai

- 1 Nesuteikia apsaugos jei vartotojas praranda prieigą prie įrenginio
- 2 Užpuolikui lengva apeiti autentifikaciją naudojant VPN

Tikslesnė geopozicionavimo versija. Leidžia nustatyti teritoriją, kurioje vartotojui leidžiama autentifikuotis. Dažniausiai naudojama telefonuose ar nešiojamuose kompiuteriuose, kuriuose galima tiksliai nustatyti įrenginio vietą naudojant GPS.

Privalumai

- 1 Labai paprasta vartotojams
- 2 Apsaugo nuo užpuolikų, puolančių nuotoliniu būdu

Trūkumai

- 1 Nesuteikia apsaugos jei vartotojas praranda prieigą prie įrenginio
- 2 Neapsaugo nuo vidinių informatorių
- 3 Neapsaugo nuo užpuolikų esančių fiziškai arti aptvertos teritorijos

Tai, ką vartotojas daro

Vartotojo elgesiu pagrįstas autentifikavimas yra pagrįstas vartotojo elgsena - tai kaip rašo klaviatūra, tai kaip judina pelę. Rečiausiai naudojamas MFA metodas. Sudėtingiausias implementuoti

Elgesio profiliavimas pagrįstas vartotojo sąveikos su programa būdu, pvz., prisijungimo paros laiku, naudojamais įrenginiais ir aplikacijos naršymo būdu. Tampa vis dažniau naudojama *web* aplikacijose.

Privalumai

- 1 Nereikalauja vartotojo sąveikos
- 2 Gali būti naudojamas nuolatiniam vartotojo autentifikavimui.

Trūkumai

- 1 Pirmos elgesio profiliavimo sistemų implementacijos buvo netikslios
- 2 Reikalauja didelio kiekio duomenų apie vartotoją
- 3 Gali būti sudėtinga implementuoti aplinkose, kuriose vartotojo elgesys dažnai keičiasi

Pvz. laikas tarp klavišų paspaudimų, laikas tarp klavišo paspaudimo ir atleidimo, pelės greitis ir pagreitis. Retai naudojamasi praktiškai.

Privalumai

- 1 Gali būti naudojamas be papildomos įrangos
- 2 Nereikalauja vartotojo sąveikos
- 3 Gali būti naudojamas nuolatiniam vartotojo autentifikavimui
- 4 Gali būti naudojamas nustatyti, kada vartotojas yra verčiamas naudotis sistema
- 5 Gali būti naudojamas nustatyti, kada vartotojas yra netinkamoje būsenoje naudotis sistema

Trūkumai

- 1 Nepakankamai tikslu, kad būtų naudojama kaip vienintelis autentifikavimo metodas

Analizuoja asmens eiseną kameromis ir sensoriais. Dažniausiai naudojama fizinei apsaugai. Vartotojo eiseną galima įvertinti telefonuose esančiais akcelerometrais.

Privalumai

- 1 Labai sudėtinga suklastoti
- 2 Gali būti naudojama be vartotojo sąveikos

Trūkumai

- 1 Reikalauja specialios aparatinės įrangos

Teisiniai reikalavimai

Šiuo metu, pagal ES General Data Protection Regulation (GDPR) MFA nėra reikalaujamas. Išskyrus pinigų pervedimus virš 50€.

Kada reikalauti MFA?

MFA turėtų būti taikomas tuomet, kai vartotojas autentifikuojasi. Taip pat, gali būti taikoma kai vartotojas:

- keičia slaptažodį
- keičia el. pašto adresą asocijuotą su paskyra
- išjungia MFA
- sesijoje gauna aukštesnes teises

Jei vartotojams yra suteikiama galimybė prie sistemos prisijungti keliais būdais, visiems būdams turėtų būti taikoma MFA.

Vartotojo patirties gerinimas

Dažnas reikalavimas papildomai autentifikuotis MFA vartotoją gali erzinti. Todėl, vartotojas gali išvis išjungti MFA. Rizika paremtas MFA gali sumažinti MFA reikalavimo dažnumą, nes MFA bus reikalaujamas tik tada, kai vartotojas atliks rizikingą veiksmą.

Pavyzdžiui:

- Reikalauti MFA, kai vartotojas prisijungia iš naujo įrenginio
- Reikalauti MFA, kai vartotojas prisijungia iš vietos, kuri laikoma pavojinga
- Kai vartotojo IP adresas nepatenka į saugių adresų sąrašą

Nepavykę prisijungimo bandymai

Kai vartotojas teisingai suveda slaptažodį, bet nepavyksta autentifikuotis antru faktoriumi, gali būti variantai:

- Vartotojas prarado prieigą prie antro autentifikavimo faktoriaus
- Vartotojo slaptažodis buvo nulaužtas

Tokiais atvejais, reiktų atlikti šiuos veiksmus:

- Nurodyti vartotojui pasinaudoti kitu MFA metodu
- Leisti vartotojui iš naujo nustatyti MFA
- Pranešti vartotojui apie nepavykusį bandymą prisijungti. Pranešime turėtų būti laikas, naršyklė, ir vieta iš kurios jis jungėsi

MFA nustatymas iš naujo

Sudėtingiausia MFA implementacijos dalis - tinkamai apdoroti vartotojus, kurie pamiršo ar pametė papildomus MFA faktorius. Taip gali nutikti, nes:

- Vartotojas perinstaliavo programą ar operacinę sistemą neišsaugojęs sertifikatų
- Vartotojas prarado telefoną neišsaugojęs OTP atkūrimo kodo
- Vartotojas pakeitė telefono numerį

Kad vartotojai neprarastų prieigos prie savo paskyrų, o užpuolikai negautų neteisėtos prieigos, reikalinga parinkti tinkamą MFA atstatymo metodą. Metodų pavyzdžiai:

- Pateikti vartotojui vienkartinį atstatymo kodą, kai pirmą kartą nustato MFA
- Reikalauti nustatyti kelis MFA metodus iš karto
- Išsiųsti vienkartinį atstatymo kodą vartotojo el. paštu
- Reikalauti vartotojui susisiekti su klientų aptarnavimo skyriumi ir turėti griežtą autentifikavimo sistemą